

CashALL Partner Mobile App — Technical API Handoff

Official API Contracts, Real Request/Response Schemas, Security Audit & Backend Integration Guide

1. Production & Staging Environment Status

This section directly answers the mobile engineering team's queries regarding the production and staging backend infrastructure.

Environment	Status	Base URL & Service Host	Verification & Audit Notes
Production	WORKING (VERIFIED)	https://www.cashall.in/api/v1 Supabase: jqysknhobtpcbyylnfc	Live test to /api/health returned HTTP 200 OK: status: 'ok', database: 'connected'. Serving live orders.
Staging / Dev	DOES NOT EXIST	None configured	'No separate staging environment is currently configured.' Single git branch (main), single Vercel project, and single Supabase DB.

2. Safe Environment Variable Reference (Variable Names Only)

To safeguard infrastructure security, secrets are never bundled into mobile binaries. Below is the variable classification:

Category	Variable Name	Scope	Purpose / Security Rule
Supabase Public	NEXT_PUBLIC_SUPABASE_URL	PUBLIC	Supabase API project URL (safe for mobile client).
Supabase Public	NEXT_PUBLIC_SUPABASE_ANON_KEY	PUBLIC	Client JWT with Row Level Security (safe for mobile client).
Supabase Secret	SUPABASE_SERVICE_ROLE_KEY	SECRET	NEVER GIVE TO DEVELOPER. Full root DB bypass key.
Supabase Secret	SUPABASE_JWT_SECRET	SECRET	Used server-side for signing and verifying Auth JWTs.
Database	DATABASE_URL	SECRET	Direct PostgreSQL TCP connection string for Prisma.
Firebase Client	NEXT_PUBLIC_FIREBASE_API_KEY	PUBLIC	Client-side Firebase API key for phone OTP.
Firebase Client	NEXT_PUBLIC_FIREBASE_PROJECT_ID	PUBLIC	Firebase project identifier for SMS phone auth.
Integrations	GOOGLE_SHEETS_WEBHOOK_URL	SECRET	Internal Google Sheets accounting auto-sync webhook.
Mailer	RESEND_API_KEY / SMTP_*	SECRET	Transactional Tax Invoice PDF email dispatch credentials.

3. Critical Agent Authentication & Security Audit

Developer Report: 'bub in backend: GET /agent/orders works without a valid login. The agent token is tok_agent_{agentId}_{timestamp}.'

AUDIT CLASSIFICATION: SECURITY VULNERABILITY (HIGH SEVERITY)

- 1. Token Generation Vulnerability:** In /api/v1/agent/login, the token is generated as tok_agent_\${agent.id}_\${Date.now()}. This is an unencrypted, unsigned plain-text string containing the agent ID and a timestamp. It is not a cryptographically signed JWT.
 - 2. Completely Unauthenticated Orders Endpoint:** In /api/v1/agent/orders, the server extracts agentId, phone, or name directly from URL query parameters. It **never inspects the Authorization header**. Anyone who guesses or knows an agent's phone can view customer PII, phone numbers, doorstep addresses, and payout amounts.
 - 3. Middleware Fallback Flaw:** In lib/middlewares/auth.ts (verifyAuthToken), if a request is received with **no Authorization header**, it automatically falls back to role: 'ADMIN', uid: 'admin_master_1!'. In endpoints like GET /api/v1/partner/orders, this leaks ALL orders in the system.
- Recommended Fix:** Generate signed HMAC-SHA256 JWTs using SUPABASE_JWT_SECRET upon agent login. Enforce Authorization: Bearer <JWT> on /api/v1/agent/orders and extract agentId strictly from the decoded token claim.

4. Agent API Authorization Matrix & Cross-Agent Risk

Cross-agent isolation analysis across all field-logistics endpoints:

Endpoint	Method	Login Enforced?	Validates Identity?	Can Tamper Other Agent?	Risk Level
/api/v1/agent/login	POST	No (Public)	Yes (DB Match)	No	Weak Token
/api/v1/agent/orders	GET	NO	NO	YES (Reads any phone)	CRITICAL

/api/v1/agent/orders/[id]/inspection	POST	NO	NO	YES (Can lock any price)	HIGH
/api/v1/agent/upload-payment	POST	NO	NO	YES (Uploads any UTR)	HIGH
/api/v1/agent/orders/[id]/complete	POST	NO	NO	YES (Completes any order)	HIGH
/api/v1/partner/orders	GET	Broken fallback	Broken fallback	YES (Leaks all pickups)	CRITICAL
/api/v1/orders/[id]/start-inspection	POST	Broken fallback	Checks Bearer	Only if unauthenticated	MEDIUM

5. Idempotency-Key & Pickup Failed API Specifications

IDEMPOTENCY-KEY STATUS: NOT CURRENTLY IMPLEMENTED

Inspection Result: Neither /api/v1/agent/upload-payment nor /api/v1/agent/orders/[id]/complete inspects or caches an Idempotency-Key or X-Idempotency-Key header.

Client Recommendation: The Partner Mobile App should immediately start sending the header Idempotency-Key: <UUIDv4> on all payment and completion mutations, and defensively disable UI buttons immediately upon tap to prevent duplicate UPI submissions.

PICKUP FAILED API: NOT CURRENTLY IMPLEMENTED (PROPOSED CONTRACT)

Endpoint: POST /api/v1/agent/orders/{orderId}/pickup-failed

Headers: Content-Type: application/json, Authorization: Bearer <TOKEN>, Idempotency-Key: <UUIDv4>

Request Body: {"failureReason": "CUSTOMER_UNAVAILABLE", "notes": "Doorstep visited; phone unreachable", "rescheduleRequested": true, "suggestedDate": "Tomorrow", "suggestedTimeSlot": "2 PM - 5 PM", "agentLocation": {"latitude": 22.5726, "longitude": 88.3639}}

Failure Reasons: CUSTOMER_UNAVAILABLE, CUSTOMER_REFUSED, INCORRECT_ADDRESS, DEVICE_MISMATCH, PRICE_DISAGREEMENT, FAKE_DEVICE, OTHER.

Database Transitions: Order.status -> CANCELLED, Pickup.status -> FAILED, logs to AuditLog.

6. Complete CashALL API Inventory Matrix (45 Endpoints)

Complete breakdown of all endpoints currently compiled in the Next.js App Router:

Method	Endpoint Path	Category	Purpose / Capability	Safe for Partner App?
POST	/api/v1/agent/login	Agent Auth	Agent mobile credentials login	YES
GET	/api/v1/agent/orders	Agent Logistics	Fetch assigned orders (query param phone)	USE WITH FIX
POST	/api/v1/agent/orders/[id]/inspection	Agent QC	Submit physical inspection & lock final price	USE WITH FIX
POST	/api/v1/agent/upload-payment	Payment	Upload manual UPI screenshot & 12-digit UTR	USE WITH FIX
POST	/api/v1/agent/orders/[id]/complete	Order Lifecycle	Mark COMPLETED & PAID, sync sheets, email invoice	USE WITH FIX
GET	/api/v1/orders/[id]	Core Order	Fetch single order, address & diagnostic details	YES
GET/POST	/api/v1/orders/[id]/generate-bill	Invoicing	Fetch structured Bill of Sale data object	YES
POST	/api/v1/orders/[id]/start-inspection	Order Lifecycle	Transition status to INSPECTION_STARTED	USE WITH FIX
POST	/api/v1/orders/[id]/verify-identity	KYC Verification	Submit customer Aadhaar/PAN mask verification	YES
POST	/api/v1/orders/[id]/device-received	Custody	Confirm physical device custody handover	YES
POST	/api/v1/orders/[id]/esign	Legal eSign	Customer digital signature & SHA-256 hash	YES
GET	/api/v1/catalog	Catalog	Fetch brands, popular models & storage variants	YES
GET	/api/v1/catalog/questions	Catalog	Fetch 5 diagnostic inspection question sets	YES
POST	/api/v1/quotes/calculate	Pricing	Run pricing engine to re-calculate device quote	YES
POST	/api/v1/storage/upload	Media Storage	Direct upload to Supabase Storage with signed URL	YES
POST	/api/v1/notifications/register	Push Alerts	Register agent FCM device token	YES
GET	/api/health	System	Health check & DB connectivity ping	YES
POST	/api/sync-sheets	Accounting	Internal Google Sheets webhook auto-sync	Server Only

POST	/api/v1/orders/create	Customer	Website customer order placement	Customer Only
GET	/api/v1/orders/user	Customer	Customer order history by phone query	Customer Only
POST	/api/v1/orders/[id]/accept-offer	Customer	Customer accepts revised price offer	Customer Only
POST	/api/v1/orders/[id]/cancel	Customer	Customer cancels order	Customer Only
POST	/api/v1/auth/admin-login	Admin Auth	Web admin operator credentials login	Admin Only
GET/POST	/api/v1/admin/orders	Admin Portal	Web admin order management grid	Admin Only
POST	/api/v1/admin/orders/[id]/assign-agent	Admin Portal	Assign field agent to order	Admin Only
POST	/api/v1/admin/orders/[id]/send-bill-email	Admin Portal	Manually re-send Tax Invoice PDF	Admin Only

7. Comprehensive API Request / Response Contracts (Copy-Paste Ready)

The exact request/response schemas implemented in the CashALL production codebase:

7.1 POST /api/v1/agent/login

Headers: Content-Type: application/json | **Auth:** None

REQUEST BODY (JSON)

```
{
  "name": "SANGEET SHAW",
  "password": "Ank933967@"
}
```

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "token": "tok_agent_agent_sangeet_shaw_1724912345678",
  "agent": {
    "id": "c7a84e20-3b91-49fa-9eb2-8b7a951d8b6c",
    "name": "SANGEET SHAW",
    "email": "sangeetshaw39@gmail.com",
    "phone": "6289477287",
    "role": "AGENT"
  }
}
```

ERROR RESPONSES (400, 401)

```
// 400 Bad Request:
{"success": false, "error": "Agent name, email, or phone number is required"}

// 401 Unauthorized:
{"success": false, "error": "Invalid password. Your login password is your registered 10-digit phone number."}
```

7.2 GET /api/v1/agent/orders?phone=6289477287

Query Params: phone (10 digits) or agentId (UUID) or name | **Auth:** Insecure (fix in progress)

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "orders": [
    {
      "id": "080b031c-b29e-4c74-8b65-9831d17d52e5",
      "orderNumber": "CA61962",
      "customerName": "Rohan Das",
      "customerPhone": "9830123456",
      "customerEmail": "rohan.das@example.com",
      "deviceName": "Apple iPhone 13 (128 GB)",
      "imeiNumber": "356789102345678",
      "estimatedPrice": 24500,
      "finalPrice": 22000,
      "amount": 22000,
      "address": "Flat 4B, Greenfield Heights, Rajarhat, Kolkata, West Bengal - 700135",
      "pickupDate": "Tomorrow",
      "pickupTimeSlot": "10 AM - 1 PM",
      "pincode": "700135",
      "status": "ACCEPTED",
      "paymentStatus": "PENDING",
      "urn": null,
      "paymentScreenshotUrl": null,
      "agentName": "SANGEET SHAW",
      "quoteNumber": "QA54921",
      "createdAt": "2026-08-29T11:20:00.000Z"
    }
  ]
}
```

7.3 POST /api/v1/agent/orders/[id]/inspection

Path Param: id = CA61962 or Order UUID | **Headers:** Content-Type: application/json

REQUEST BODY (JSON)

```
{
  "imei": "356789102345678",
  "screenFinding": "Flawless Screen",
  "bodyFinding": "Minor body scratches",
  "revisedPrice": 22000,
  "reason": "Minor scratches on body frame",
  "customerEmail": "rohan.das@example.com",
  "agentName": "SANGEET SHAW"
}
```

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "message": "Physical inspection completed! Final payout offer locked at ₹22,000.",
  "order": {
    "id": "080b031c-b29e-4c74-8b65-9831d17d52e5",
    "orderNumber": "CA61962",
    "status": "ACCEPTED",
    "finalPrice": 22000
  }
}
```

7.4 POST /api/v1/agent/upload-payment

Headers: Content-Type: multipart/form-data | **Header:** Idempotency-Key: <UUIDv4>

REQUEST FORM-DATA FIELDS

```
orderId: CA61962
urn: 423456789012
agentId: c7a84e20-3b91-49fa-9eb2-8b7a951d8b6c
file: <binary_image_data> (image/png)
```

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "message": "Payment screenshot & 12-digit URN uploaded and saved. Awaiting manual Admin approval.",
  "order": {
    "id": "080b031c-b29e-4c74-8b65-9831d17d52e5",
    "orderNumber": "CA61962",
    "urn": "423456789012",
    "paymentScreenshotUrl": "https://jqysknhobtpcbbyltnfc.supabase.co/storage/v1/object/sign/payment-screenshots/urn_CA61962_1724912345.png?token=..."
  },
  "urn": "423456789012",
  "paymentScreenshotUrl": "https://jqysknhobtpcbbyltnfc.supabase.co/storage/v1/object/sign/payment-screenshots/urn_CA61962_1724912345.png?token=..."
}
```

7.5 POST /api/v1/agent/orders/[id]/complete

Path Param: id = CA61962 | **Headers:** Content-Type: application/json, Idempotency-Key: <UUIDv4>

REQUEST BODY (JSON)

```
{
  "finalPrice": 22000,
  "utr": "423456789012",
  "agentName": "SANGEET SHAW"
}
```

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "message": "Order #CA61962 marked as COMPLETED & PAID. Tax Invoice email sent to rohan.das@example.com via Resend.",
  "emailSent": true,
  "emailProvider": "Resend",
  "emailError": null,
  "order": {
    "id": "080b031c-b29e-4c74-8b65-9831d17d52e5",
    "orderNumber": "CA61962",
    "status": "COMPLETED",
    "finalPrice": 22000,
    "urn": "423456789012"
  }
}
```

7.6 GET /api/v1/orders/[id]/generate-bill

Path Param: id = CA61962 | **Auth:** Public read-only

SUCCESS RESPONSE 200 OK

```
{
  "success": true,
  "data": {
    "billData": {
      "billNumber": "CA61962_2026",
      "orderNumber": "CA61962",
      "orderDate": "2026-08-29T11:20:00.000Z",
      "completionDate": "2026-08-30T10:15:00.000Z",
      "seller": {
        "name": "Rohan Das",
        "phone": "9830123456",
        "address": "Flat 4B, Greenfield Heights, Rajarhat, Kolkata, West Bengal - 700135"
      },
      "buyer": {
        "name": "AARNA ENTERPRISE",
        "platform": "CashALL Platform",
        "gstIn": "19AVPPG9800JIZ3",
        "address": "Howrah, West Bengal",
        "assignedAgent": "SANGEET SHAW"
      },
      "device": {
        "brand": "Apple",
        "model": "iPhone 13",
        "variant": "128 GB",
        "deviceName": "Apple iPhone 13 (128 GB)",
        "imei1": "356789102345678"
      },
      "financials": {
        "estimatedPrice": 24500,
        "finalPurchasePrice": 22000,
        "paymentMethod": "UPI Transfer",
        "utrNumber": "423456789012",
        "paymentStatus": "PAID"
      },
      "declarations": {
        "sellerDeclarationText": "This is a computer-generated receipt issued by CashALL. The seller (named above) has voluntarily sold the device to CashALL at the agreed final price.",
        "documentHash": "sha256_verified_aarna_cashall"
      }
    }
  }
}
```

8. Partner App API Requirements Categorization

Category	Backend API Status	Endpoints Involved
A. Ready to Use	Available in Production	/catalog, /catalog/questions, /orders/[id], /orders/[id]/generate-bill, /quotes/calculate, /storage/upload, /notifications/register, /orders/[id]/verify-identity, /orders/[id]/esign.
B. Needs Security Fix	Vulnerable (Token/Auth)	/agent/login (Sign JWT), /agent/orders (Enforce Bearer JWT), /agent/orders/[id]/inspection (Validate agent), /agent/upload-payment, /agent/orders/[id]/complete.
C. Needs Modification	Missing Idempotency	/agent/upload-payment and /agent/orders/[id]/complete require server-side Idempotency-Key header processing and caching.
D. Needs New API	Not Currently Implemented	POST /api/v1/agent/orders/[id]/pickup-failed (For recording failed visit, customer refusal, doorstep GPS coordinates) and GET /api/v1/agent/profile.

9. Recommended Partner Mobile App Execution Flow

The exact sequence of API calls to be executed by the Partner Mobile App:

Step	Mobile Screen / Action	API Endpoint Called	Data Exchanged / Outcome
1	Agent Login	POST /api/v1/agent/login	Sends phone/password; receives agent session token.
2	Assigned Orders List	GET /api/v1/agent/orders	Fetches all active doorstep pickups assigned to agent.
3	Doorstep Arrival	POST /orders/[id]/start-inspection	Locks order status to INSPECTION_STARTED.
4A	Pickup Failed / Refused	POST .../pickup-failed [NEW]	Records reason, notes, GPS coordinates; cancels order.

4B	QC Physical Diagnostic	POST /api/v1/agent/.../inspection	Submits screen/body findings, IMEI; locks finalPrice.
5	Customer e-KYC	POST /orders/[id]/verify-identity	Submits Aadhaar/PAN mask; status -> ACCEPTED.
6	Digital e-Signature	POST /orders/[id]/esign	Customer signs declaration; generates SHA-256 hash.
7	Manual UPI Payment	POST /api/v1/agent/upload-payment	Uploads GPay/Paytm screenshot & 12-digit UTR.
8	Order Settlement	POST /api/v1/agent/.../complete	Status -> COMPLETED; syncs Google Sheets; emails PDF invoice.
9	Digital Bill Display	GET /orders/[id]/generate-bill	Renders official Aarna Enterprise GST Tax Invoice.

10. Developer Handoff Checklist

WHAT TO PROVIDE TO THE PARTNER APP DEVELOPER:

- **This Technical PDF Document:** Complete API contracts and schemas.
- **Production API Base URL:** <https://www.cashall.in/api/v1>
- **Supabase Public Project URL:** <https://jqysknhobtpcbbyltnfc.supabase.co>
- **Supabase Public Anon Key:** Public client key with Row Level Security (RLS).
- **Firestore Client Config:** Client API key, project ID, sender ID for phone OTP.
- **Active Test Agent Account:** Name: SANGEET SHAW, Phone: 6289477287, Password: Ank933967@.

WHAT YOU MUST NEVER GIVE TO THE DEVELOPER:

- **DO NOT GIVE:** SUPABASE_SERVICE_ROLE_KEY (Grants total DB root bypass).
- **DO NOT GIVE:** DATABASE_URL / Direct PostgreSQL credentials (Exposes TCP DB ports).
- **DO NOT GIVE:** RESEND_API_KEY / SMTP credentials (Internal email delivery only).
- **DO NOT GIVE:** GOOGLE_SHEETS_WEBHOOK_URL (Internal accounting webhook).
- **DO NOT GIVE:** META_CONVERSIONS_API_ACCESS_TOKEN (Marketing pixel secret).
- **DO NOT GIVE:** Production Vercel deployer/admin tokens.